

13.6. Security Best Practices

This section describes best practices that Matter implementors SHOULD implement. Matter implementors SHALL indicate whether they comply or not to the best practices. Matter certification will not itself test that these requirements have been met.

13.6.1. Cryptography

- a. Devices and Nodes SHOULD include protection (if it exists) against known remote attacks that can be used to extract or infer cryptographic key material. [CM107 for T94]
- b. Devices SHOULD protect the confidentiality of attestation (DAC) private keys. The level and nature of protection for these keys may vary depending on the nature of the Device. [CM77 for T22]
- c. Nodes SHOULD protect the confidentiality of Node Operational Private Keys. The level and nature of protection for these keys may vary depending on the nature of the Nodes. [CM87 for T87, T110, T120]
- d. Cryptographic keys SHALL be randomly chosen using a cryptographically secure random number generator in accordance with algorithms defined in [Section 3.1, “Deterministic Random Bit Generator \(DRBG\)”](#). [CM39 for T39]
- e. Devices SHALL use non-repeating initialization vectors for a given session key. [CM78 for T81]

13.6.2. Commissioning and Administration

- a. Manufacturers SHOULD control the number of DACs issued under their Vendor ID. [CM24 for T23, T34]
- b. Where practical, the Onboarding Payload SHOULD NOT be photograph-able or visible when installed (e.g., QR code hidden with a flap). [CM89 for T90]
- c. Uncommissioned Devices SHOULD only be available to be commissioned with some form of physical proximity user interaction (e.g. power cycle or button press). [CM3 for T15, T90, T92]
- d. For Devices subject to physical tampering (e.g. doorbell, camera, door lock, devices designed for outdoor use cases), the physical interaction to initiate commissioning and/or the Onboarding Payload (QR code, NFC Tag or Manual Pairing Code) SHOULD NOT be accessible to a physical attacker. E.g. Onboarding Payload is removable or not on the device, the button used to initiate commissioning for the lock is inside the house. [CM4 for T3, T84]
- e. A Commissioner or Administrator SHOULD only add Root Certificates that it trusts to a Node. [CM36 for T153]
- f. A device manufacturer SHOULD implement [Basic Commissioning Method](#) only for devices that adequately secure the [Passcode](#). [CM154 for T173]
- g. Commissioners and Administrators SHOULD carefully control which Nodes get Administer, Manage, or Operate privilege, especially for safety-critical systems like Door Locks and Smoke CO Alarms. [CM244 for T17, T20, T59, T94, T230]
- h. The NFC-based commissioning session started by a non-authorized user (for instance in a shop) SHALL be prevented. Different solutions exist depending on the form factor of the Matter